# 目　　录

摘 要 ..... 1

第一章 作品概述 ..... 2

第二章 作品设计与实现 ..... 4

第三章 作品测试与分析 ..... 16

第四章 创新性和特色说明 ..... 20

第五章 竞品分析 ..... 22

第六章 总结 ..... 23

# 摘 要

针对网络安全漏洞检测与报告交付的行业痛点，本项目设计实现本地化智能安全检测与漏洞报告系统——智安鉴。

系统以Web应用为载体，覆盖资产台账、多源解析、报告全生命周期治理、多格式导出。核心技术包含：CVSSv3.1量化评分引擎；规则+AI质检；无向量库本地RAG检索机制；内置多Agent调度扫描引擎，实现扫描研判一体化流水线。

系统采用React 18、TypeScript与Vite构建前端，后端采用Flask 3.1、FastAPI与Celery驱动扫描任务，搭配MySQL 8、 PostgreSQL 16、Redis 7分层储存，已实现14大功能模块。交付前完成全量端到端回归，32个模块编译零错误，核心功能与干净环境冒烟测试全通过，服务启动小于2秒，数据全程在受控部署域内、开箱即用。

系统可应用于渗透测试、合规测评场景，后续将向知识图谱化方向演进。

**关键词：**漏洞报告自动化生成；CVSSv3.1量化评分；本地RAG检索机制；双维度质量体检；漏洞报告全生命周期治理

# 第一章 作品概述

## 1.1 背景分析

在网络安全攻防演练、渗透测试与等级保护测评等工作中，漏洞报告是交付成果的核心载体。一份合格的漏洞报告通常需要包含漏洞名称、等级、地址、描述、危害、复现过程、整改建议与归属证明等字段，并需符合特定单位或主管部门的文档格式要求。

当前主流扫描工具（如Nuclei、Xray等）虽然能输出大量检测结果，但其输出为JSON/JSONL等结构化数据，距离可直接交付的正式报告仍有较大差距；BurpSuite等工具的报告模板定制能力有限，难以满足政企单位对公文格式、盖章版式的要求。与此同时，行业还存在以下核心痛点：

（1）等级判定主观化，缺乏统一量化标准：漏洞等级判定高度依赖工程师个人经验，同一漏洞在不同人员手中可能出现高危、中危的判定差异，既缺乏可复核的量化依据，也导致整改优先级排序混乱，严重影响报告的专业性与权威性。

（2）交付质量不可控，缺少自动化质检手段一线：产出的漏洞报告常出现字段缺失、证据不足、整改建议空泛不可落地等问题，交付前的质量审核完全依赖人工抽检，效率低、覆盖不全，交付物质量参差不齐，返工率居高不下。

（3）大模型幻觉突出，整改口径难以统一：通用大语言模型虽具备强大的文本生成能力，但直接用于漏洞报告生成时，易产生与单位既有整改规范不一致的“幻觉”内容，AI产出无法直接落地，仍需大量人工校对修正，未能真正释放生产力。

（4）工具链割裂断裂，全流程数据不通：漏洞探测、结果研判、报告生成、整改跟踪四类工具相互独立，扫描器原始数据需人工导出、清洗、再导入报告工具，反复的数据搬运效率低下且易出错，更无法实现从漏洞发现到修复验证的完整生命周期跟踪。

随着大模型与检索增强生成（RAG）技术成熟，将AI与本地知识库、标准化评分规则、内置扫描引擎深度融合，成为网络安全行业降本增效、提质控险的重要方向。

## 1.2 项目挑战

本项目面临的主要挑战包括：

（1）如何将Nuclei、Burp、通用JSON、纯文本等异构、非结构化的扫描结果稳定归一化为统一的漏洞记录；

（2）如何在无重型依赖的前提下，精确实现FIRST.orgCVSSv3.1规范中随影响范围（Scope）变化的权重与取整规则；

（3）如何设计一套可解释、离线可用的报告质量规则引擎，并与AI点评形成互补；

（4）如何通过本地RAG检索在不依赖外部向量数据库的前提下约束大模型输出口径；

（5）如何在本地轻量部署下同时保证中文字体的Word/PDF正确渲染与系统自身安全；

（6）如何将漏洞扫描引擎内嵌集成，实现扫描任务调度、多Agent探测、结果自动回流的一体化流水线，并保证扫描结果与报告数据结构的无缝映射；

（7）如何在原有单机工具基础上引入多用户登录认证与权限管理，同时保持本地部署的轻量性与数据隔离安全性。

## 1.3 项目目标

设计并实现一个本地化、可扩展的智能漏洞报告自动化生成系统，形成“多源数据导入（内置扫描+外部导入+手动录入）—智能解析研判（RAG+CVSS）—结构化报告—质量体检—Word/PDF多模板产出”的一站式闭环，并配套安全专家Copilot、修复代码生成与安全测试工具箱，做到功能真实可运行、无Key亦可离线联调、界面与模板可个性化定制。系统同时支持内置引擎直接发起漏洞扫描与多用户登录协作。

# 第二章 作品设计与实现

## 2.1 整体架构

### 2.1.1 系统拓扑结构

系统采用本地化闭环部署拓扑，整体自上而下分为用户接入层、核心服务层、能力引擎层、数据存储层四个逻辑层级，React前端、Flask业务应用、FastAPI扫描引擎、数据库与Redis缓存均部署于受控部署域内，业务数据无需流出部署域。

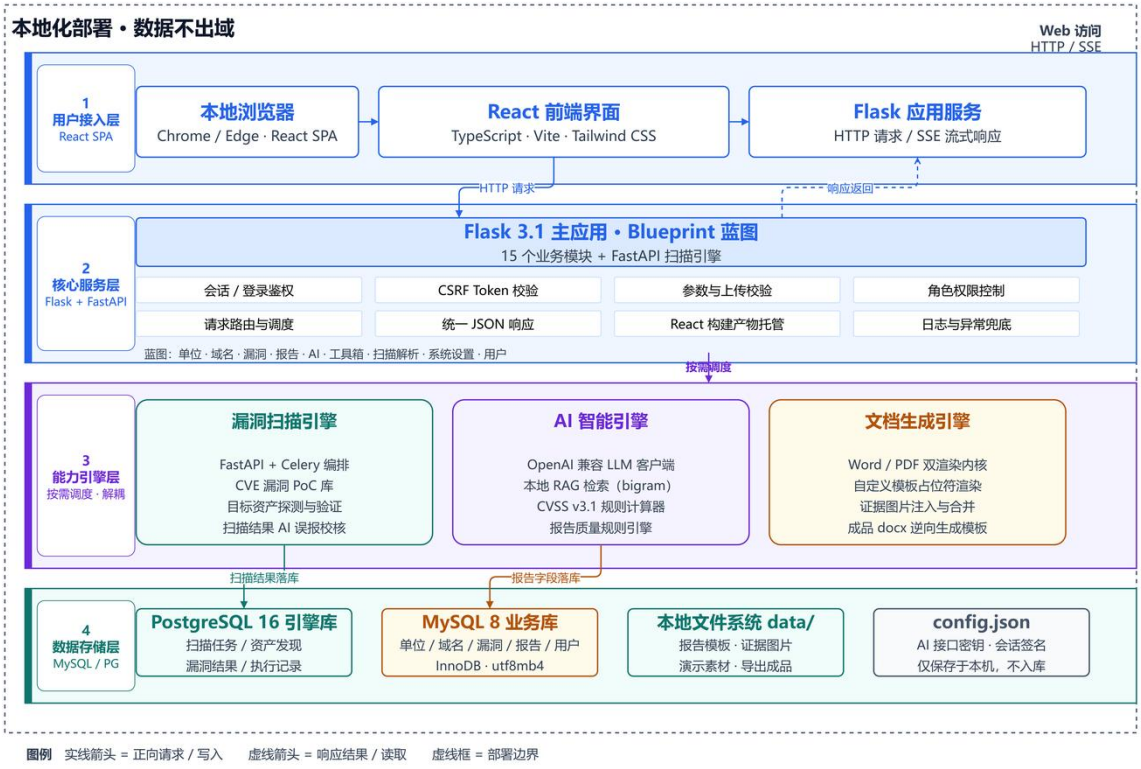



图2-1 系统拓扑结构图

各层级的组成与功能如下：

（1）用户接入层：用户通过Chrome/Edge等现代浏览器访问React Web前端，前端采用React 18、TypeScript、Vite、Tailwind CSS与React Router构建响应式单页界面，包含仪表盘、资产管理、漏洞扫描、报告管理、AI助手、系统设置等15个功能页面。普通业务请求通过HTTP/JSON接口同步响应，AI生成内容通过SSE（Server-Sent Events）协议流式输出。

（2）核心服务层：以Python Flask 3.1 Web框架承载主业务应用，以蓝图（Blueprint）机制拆分15个业务模块，统一处理鉴权校验、请求路由、业务逻辑调度与结果封装返

回；FastAPI与Celery负责扫描任务接口及异步编排。层内内置会话管理、CSRF Token校验、输入参数过滤、权限控制等安全中间件。

（3）能力引擎层：包含三大独立引擎，由核心服务层按需调度、解耦运行：

漏洞扫描引擎：内置多Agent探测调度框架，集成CVE漏洞POC库，负责目标资产探测、漏洞验证与AI误报校核

AI智能引擎：集成LLM兼容客户端、本地RAG检索器、CVSSv3.1评分器、质量规则引擎四大组件

文档生成引擎：集成Word/PDF双渲染内核，负责自定义模板渲染、证据图片注入、多文档合并

（4）数据存储层：采用业务库与扫描库分离的持久化方案。单位、资产、报告、用户等结构化业务数据存储于MySQL 8（InnoDB、utf8mb4）；扫描任务、资产发现、漏洞结果与执行记录存储于PostgreSQL 16；Redis 7负责任务队列与热点缓存；报告模板、证据图片、演示素材均存储于本地文件系统；AI接口密钥仅保存于本地config.json配置文件，不入库、不落业务日志。

整体拓扑的核心数据流为：用户在接入层发起操作请求，核心服务层完成鉴权与逻辑调度，按需调用对应能力引擎执行计算，最终结果经核心服务层封装后返回前端展示，同时按需将任务写入Redis队列，将业务数据写入MySQL、扫描数据写入PostgreSQL。全链路数据均在受控部署域内流转。

### 2.1.2 三层软件架构

系统采用B/S三层架构。展示层基于React 18、TypeScript、Vite与Tailwind CSS构建响应式单页界面，使用React Router组织页面路由，通过fetch+SSE实现普通请求与AI流式输出；业务层基于Python 3、Flask 3.1与FastAPI，按蓝图划分为资产、域名、漏洞、报告、AI、工具箱、扫描器解析、系统设置等模块，并由Celery与Redis完成任务队列调度；数据层采用MySQL 8存储业务数据、PostgreSQL 16存储扫描数据，文档生成基于python-docx、docxtpl、docxcompose，PDF生成基于reportlab。

AI子系统由五部分构成：①兼容OpenAI协议的LLM客户端；②基于bigram的本地RAG检索器；③CVSSv3.1规则计算器；④报告质量规则引擎；⑤扫描任务调度与AI校核模块。

整体数据流为：用户维护资产台账→发起内置漏洞扫描→多Agent执行探测与验

证→自动回收结果并归一化解析→RAG召回本地知识并交由LLM生成规范字段→CVSS量化等级→用户编辑确认→质量体检→选择Word/PDF模板一键导出。

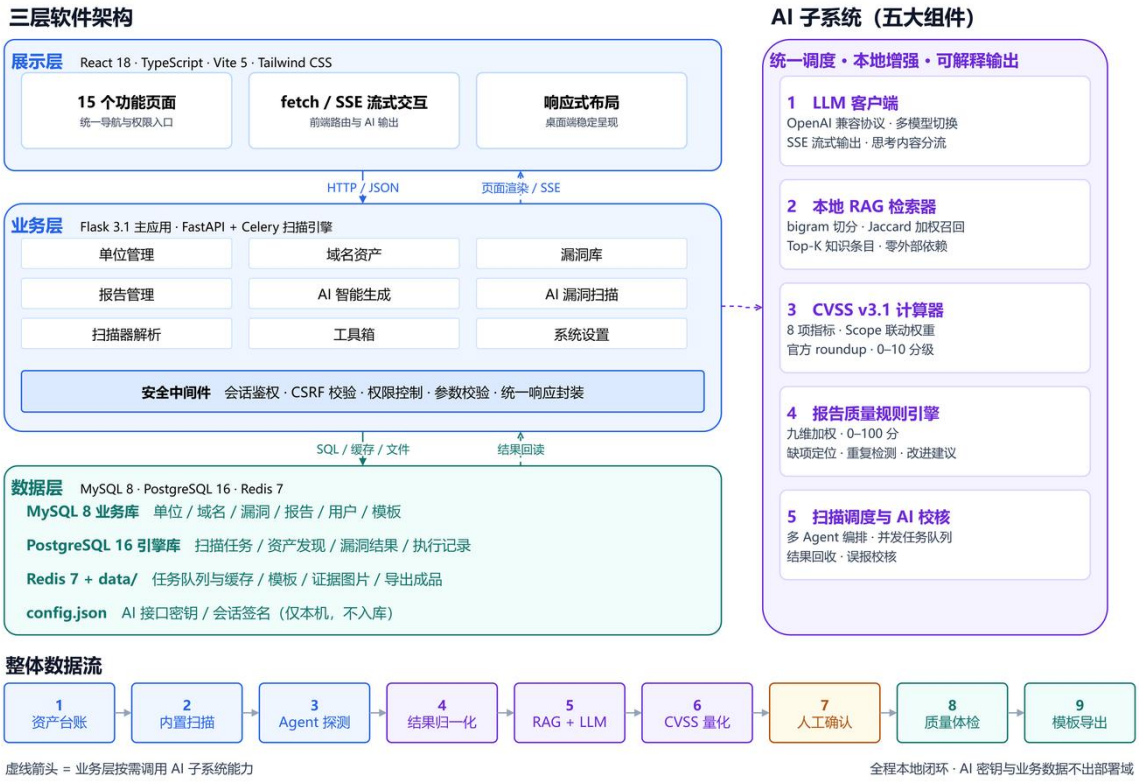



图2-2 系统整体架构图

### 2.1.3 核心业务流程

系统端到端业务流程遵循「探测—研判—交付—闭环」四阶段逻辑，覆盖从任务发起到整改验证的完整链路，各阶段数据无缝流转，无需人工中转。

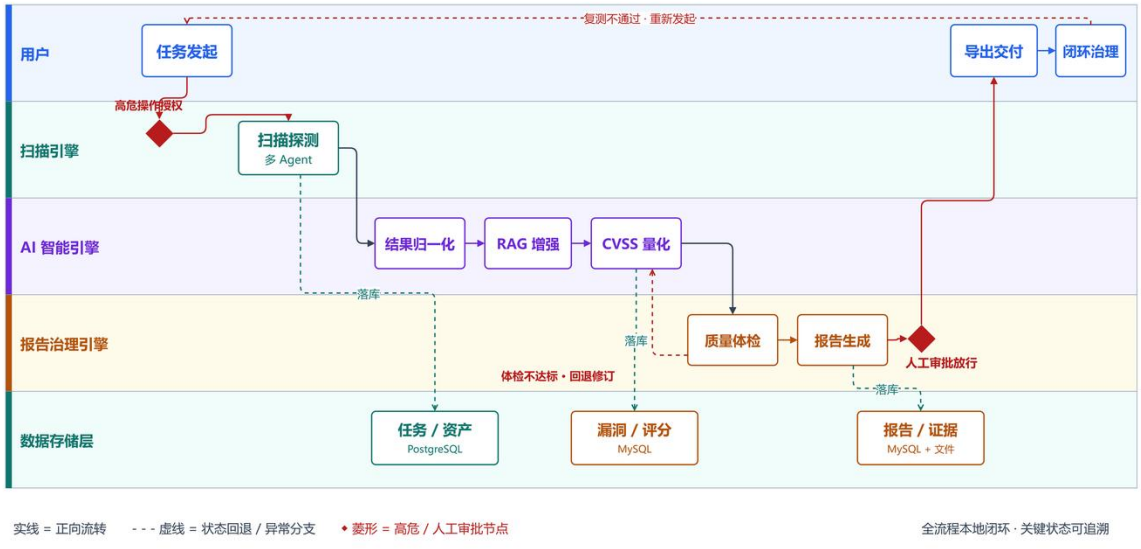



图2-3 核心业务流程图

### 2.1.4 系统角色与用例

系统设置三类用户角色，不同角色权限边界清晰，功能按需开放，保障数据安全与操作合规。

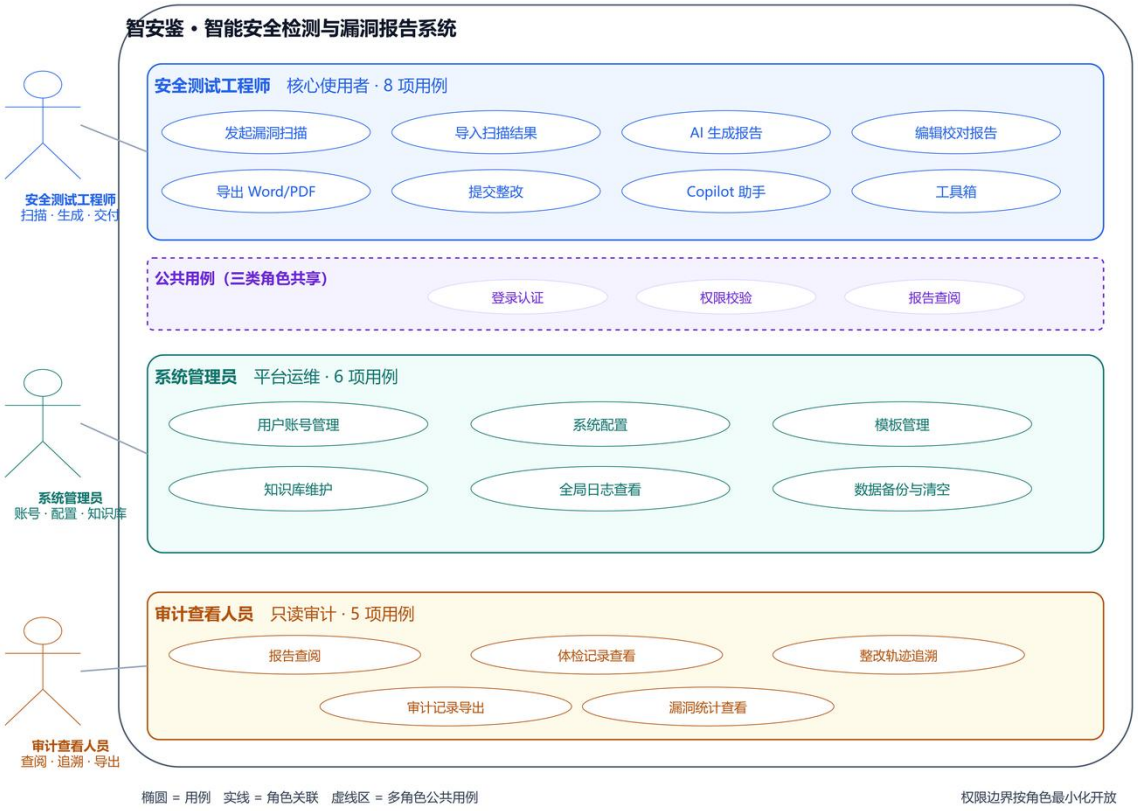



图 2-4 系统角色用例图（URM 图）

各角色核心用例：

安全测试工程师（核心使用者）：发起漏洞扫描、导入扫描结果、AI 生成报告、编辑报告、导出报告、提交整改、查看 Copilot 助手、使用工具箱。

系统管理员：用户账号管理、系统配置、模板管理、知识库维护、全局日志查看、数据备份与清空。

审计查看人员：报告查阅、质量体检记录查看、整改轨迹追溯、导出审计记录、漏洞统计查看。

## 2.2 功能模块设计

系统共分为三大层级、14 个核心功能模块，覆盖从探测到治理的全链路能力。




图 2-5 系统功能模块全景图

（1）AI漏洞扫描模块：内置漏洞扫描引擎，在业务管理中提供独立的AI漏洞扫描页面。用户输入目标地址后发起任务，系统通过多子Agent编排机制依次执行资产探测、漏洞验证、AI校核与结果汇总，页面实时跟踪扫描进度。

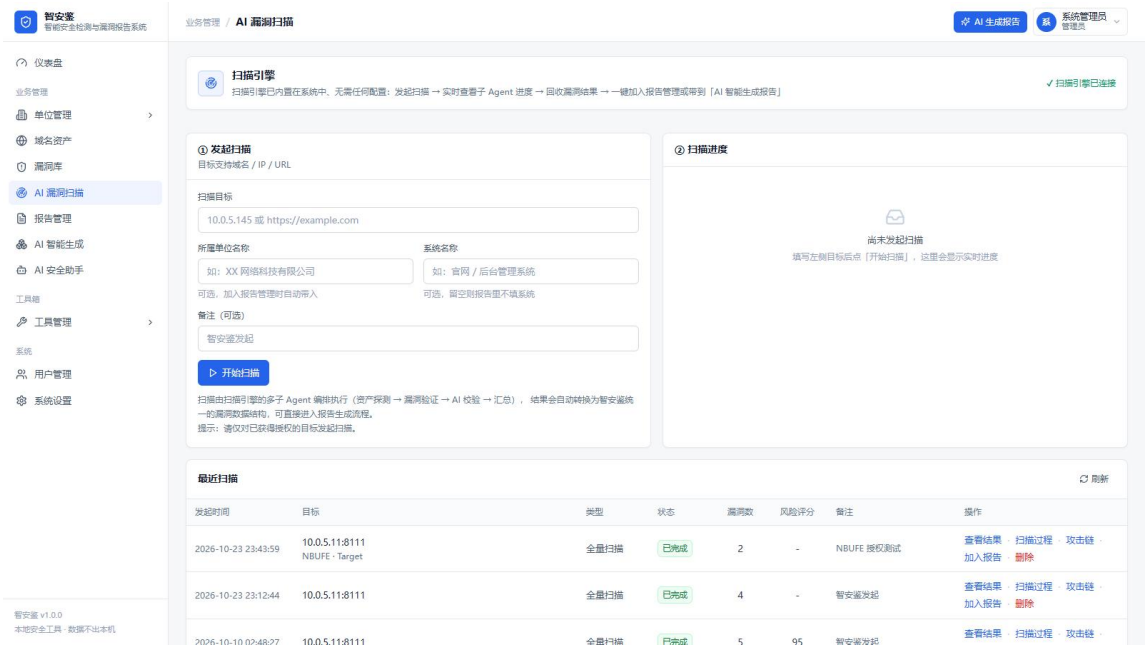



图2-6 AI漏洞扫描模块

（2）扫描器智能解析模块：自动识别NucleiJSONL/JSON、BurpSuiteXML、通用JSON（递归嗅探name/title、url/host、severity/level/risk等字段）以及纯文本，统一归

一化为内部漏洞结构，解析后自动完成同名漏洞去重、相似结果合并，避免重复录入报告库，并给出按严重程度聚合的统计。

（3）AI报告生成模块：支持内置扫描自动流入、扫描结果文件导入、手动粘贴录入三种数据输入路径，共用同一套RAG增强、CVSS评分、质量体检与模板导出链路。生成时自动召回本地知识库匹配条目注入提示词，约束大模型输出口径；支持一键生成、分析预览、内容润色、摘要提取、资产分类五类AI操作，输出结构化JSON并做字段合法性二次校验。提供模拟模式保证无Key环境全流程可联调。

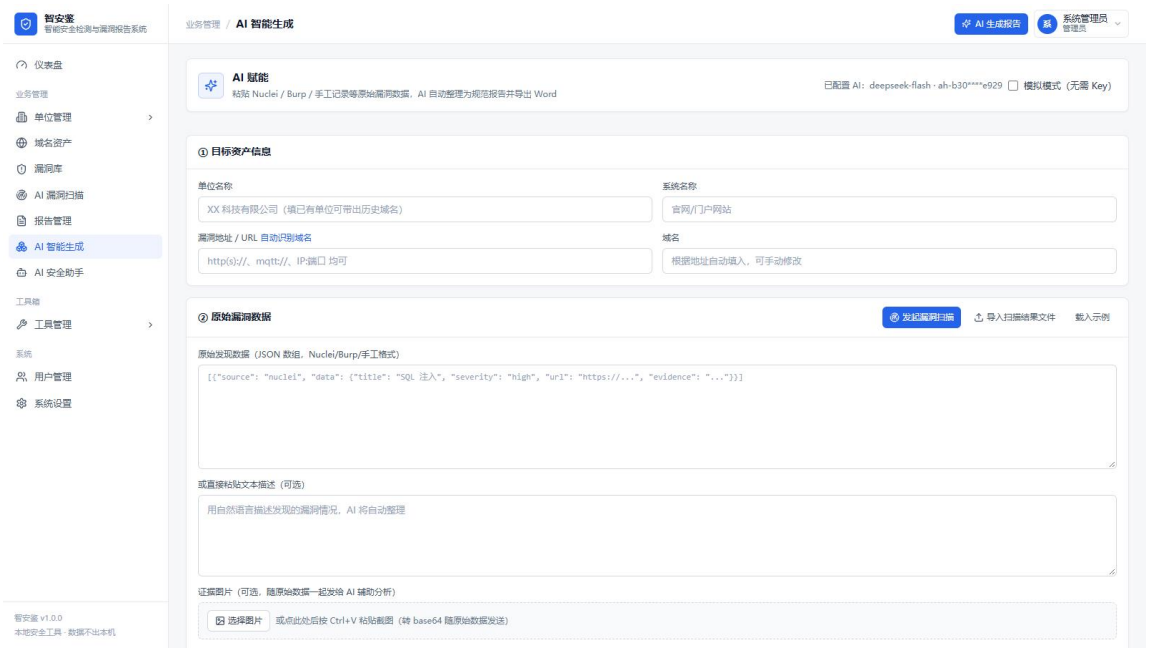



图2-7 AI智能生成页

（填入漏洞地址自动识别域名、AI模型配置与无Key模拟模式开关）

（4）漏洞知识库模块：维护常见漏洞的名称、等级、描述、危害与整改建议，既是可复用的知识资产，也是RAG检索的本地语料来源。支持词条的增删改查、批量导入与标签分类，知识条目更新后即时生效于所有AI生成场景。

（5）报告管理模块：实现报告从创建到闭环的全链路管理，支持增删改查、多条件检索、勾选批量导出，检测过程与归属证明各自支持插入多张证据图片。新建报告填入漏洞地址后自动识别域名并回填，保存时自动幂等登记单位与域名资产，确保台账与报告数据一致。

模块内置四态状态机：报告默认处于待整改状态，可依次流转为整改中、已修复待复测、复测通过（构成闭环），支持复测不通过回退与结论撤销。每次状态流转自

动记录操作时间、动作与备注，形成完整整改轨迹；后端对流转路径做合法性校验，杜绝跨阶段跳变。仪表盘实时统计四态数量、处置推进率与复测闭环率，推动漏洞从“发现通报”真正走向“修复验证”。

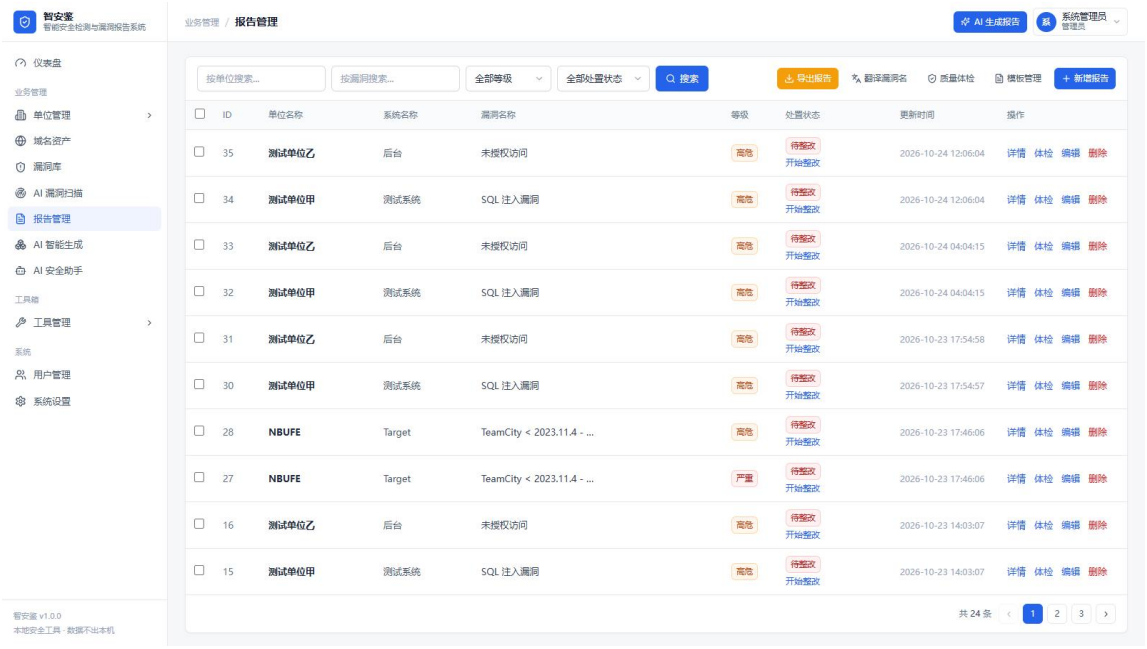



图2-8 报告管理模块：处置状态流转、质量体检分数与逐条改进建议

（6）CVSSv3.1评分模块：严格依据FIRST.org规范实现攻击向量（AV）、攻击复杂度（AC）、权限要求（PR，随Scope是否改变取0.62/0.68等不同权重）、用户交互（UI）及C/I/A影响的基础分计算公式与roundup取整，输出分值、严重等级（None/Low/Medium/High/Critical）与向量串，并可一键映射到报告等级。



图2-9 CVSS评分模块

（7）报告质量体检模块：内置可解释的本地规则引擎，从单位名称、漏洞名称、等级、地址格式、描述/危害/检测过程/整改建议/归属证明的完整性与充分性、证据图片数量、报告重复性等9个维度加权扣分，输出0－100分、等级与逐条改进建议；同时可调用大模型给出专家级亮点、问题与改进点评，实现“规则兜底+AI增强”。

（8）多模板导出与模板逆向模块：内置普通报告、网信办公文、汇总清单三套样式，支持Word与PDF双格式，PDF通过Windows宋体/黑体/仿宋实现中文与证据图片正确排版；支持用户上传任意docx模板，以{{单位名称}}等中文占位符自动填充并支持多记录合并。系统提供还成品报告逆向功能：上传一份现成漏洞报告docx，自动解析段落并预猜字段映射，用户确认后即可生成专属可复用模板；此后新增报告只需填写新漏洞信息，导出件在版式、字体与章节顺序上与原件保持一致。导出正文按送检版式默认省略域名、系统名称、报告日期与落款等冗余字段，并可在系统设置中按需调整。

（9）AI安全专家Copilot：以系统提示词约束为授权安全测试与防御服务的网络安全专家，支持多轮上下文、SSE流式逐字输出、快捷问题，可解答漏洞原理、检测思路、整改与报告规范问题；已适配deepseek-flash等带独立推理过程的思考型模型，无API Key时以模拟模式应答，保证离线也能完整演示。

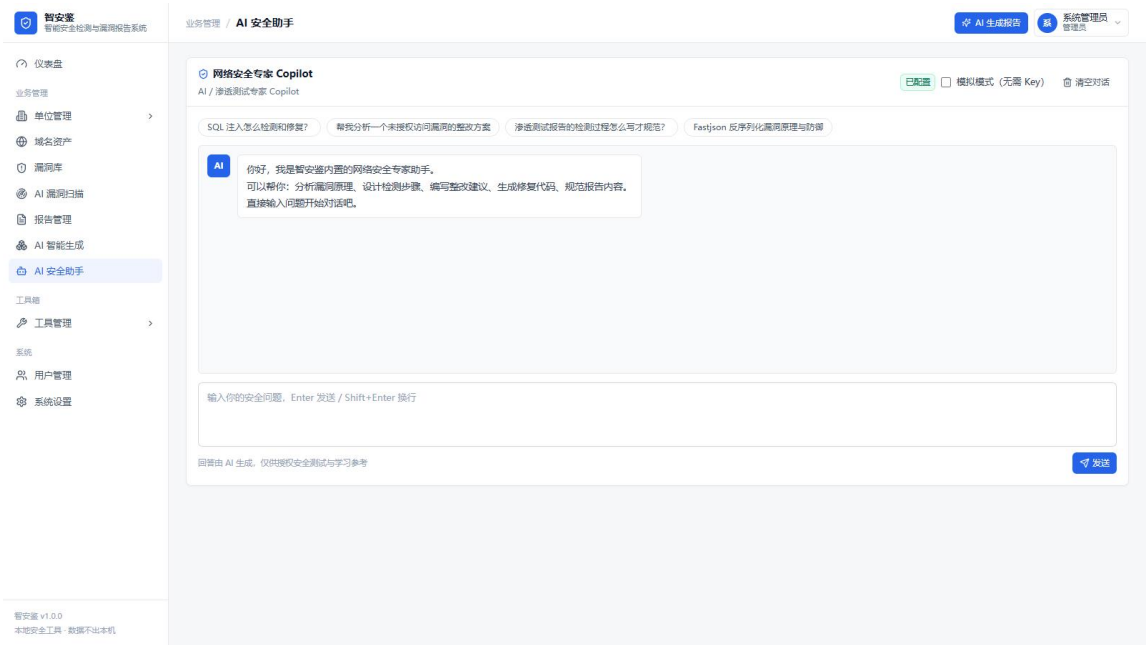



图2-10 AI安全专家Copilot

（10）AI修复代码生成：输入漏洞名称、技术栈与描述后，结合RAG知识输出根因分析、分步修复计划、多语言示例代码、修复验证方法与纵深加固建议的结构化JSON。支持Java/PHP/Python/JavaScript等主流开发语言，输出可直接使用的修复示例。

（11）资产管理模块：单位资产支持文本批量、Excel模板导入更新、ICP备案数据包解析导入，支持多标签关联；域名资产支持ICPJSON（兼容三种格式）导入、模糊查询、软删除与批量查询。

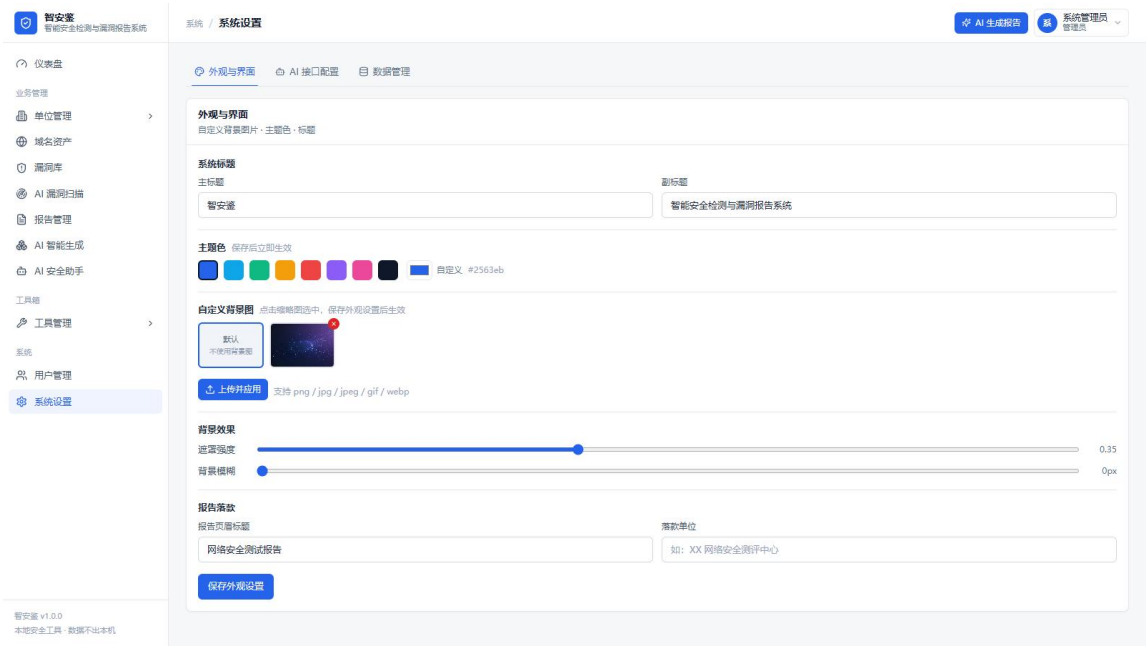



图2-11 系统设置模块

（12）用户认证与管理模块：系统启动后需登录方可使用，保障数据访问安全；提供管理员后台，支持账号的新增、编辑、删除与权限维护，使系统从单机单用户工具升级为支持多用户协作的平台，为后续报告流转审批与团队协作奠定基础。

（13）工具箱模块：随机密码生成、文本行去重、域名/IP提取、A/B文件对比、资产自动分类、CVSS评分。

（14）系统设置模块：背景图片上传与遮罩/模糊调节、主题色与系统标题定制、AI接口配置本地保存与连接测试、一键打开数据目录、演示数据导入与一键清空。

## 2.3 关键技术实现

（1）异构扫描结果归一化：针对不同工具字段差异，采用“格式特征识别+递归字段嗅探+严重程度词表归一（critical/high/medium/low/info）”策略，将多源数据映

射为统一的{名称,地址,等级,描述}结构，纯文本则通过URL/IP正则与等级关键词抽取。

（2）CVSSv3.1精确计算：完整实现ISCBase、影响分（Scope改变/不变两套公式）、可利用性分与1.08系数放大，采用规范的roundup（一位小数向上取整）函数，经验证标准向量9.8、8.5、3.5、0.0等分值与FIRST.org官方计算器完全一致。

（3）无向量库的本地RAG：对中文漏洞名称与正文做bigram切分并保留英文/数字token，以Jaccard式重合度加权（名称命中权重更高、直接包含额外加分）召回Top-K知识，拼入提示词约束模型口径；该方案零外部依赖、离线可用、响应毫秒级。

（4）LLM稳定结构化与思考模型适配：要求模型输出固定JSON，抽取时去除代码块围栏并截取JSON区间，对字段长度与等级枚举做二次校验；流式对话通过SSE逐块透传choices[].delta.content，并对deepseek-flash等思考型模型单独返回的reasoning_content推理内容做分流，对极端情况下空content做非流式兜底，保证不同模型均能稳定作答。

（5）Word/PDF双引擎与图片注入：Word端用docxtpl（Jinja2语法）渲染自定义模板，检测过程图片与归属证明图片采用相互独立的DIMG/PIMG标记分组，图片加载统一兼容base64数据、HTTP链接与本地文件三种来源，按“文字段左对齐、图片独立居中”自动分段排版，多记录用docxcompose合并，并对缺失或残留占位符静默容错；成品报告逆向生成模板时，通过段落解析与字段映射把整份docx转换为带占位符的可复用模板。PDF端用reportlab注册中文字体并将富文本HTML解析为段落与等比例缩放图片。

（6）系统自身安全：会话级CSRF Token校验全部写操作（上传接口单独做白名单）；统一HTML转义防XSS；上传扩展名/MIME与大小（50MB）白名单、文件名清洗；下载路径白名单化防目录穿越；AI密钥仅存本地config.json、不入库不落日志，业务数据不出受控部署域。

（7）内置扫描引擎集成与任务调度：将漏洞扫描引擎内嵌合入系统代码，去除对外部扫描平台的依赖；采用多Agent异步调度架构，支持单任务多目标批量探测、并发任务队列管理；内置CVE漏洞POC库，并通过多套真实漏洞靶场环境完成检测准确率调优；扫描结果自动归一化为内部漏洞结构并流入报告生成流水线，实现扫描与报告的无缝衔接；AI接口配置以智安鉴为唯一配置源，自动同步至扫描模块，避免多处配置不一致。

**智能报告生成时序：**

漏洞验证完成后，结果自动流入智能报告治理子系统，按标准化时序完成研判、质检与生成全流程，各环节解耦、可追溯、可监控。

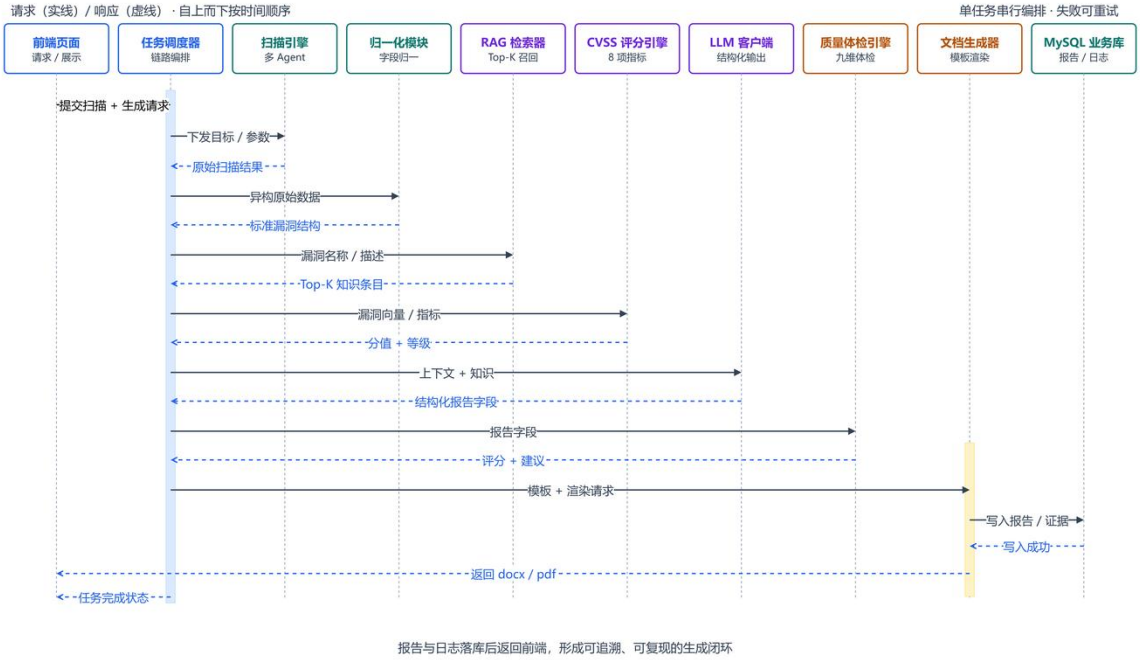



图 2-12 智能报告生成时序图

**核心时序步骤：**

1.前端向任务调度器提交扫描生成请求

2.调度器调用扫描引擎执行探测，返回原始结果

3.归一化模块解析异构数据，输出标准漏洞结构

4.RAG 检索器召回匹配知识库条目

5.CVSS 引擎计算漏洞分值与等级

6.LLM 结合知识与漏洞上下文生成规范字段

7.质量体检引擎执行 9 维度规则打分

8.文档生成器按模板渲染为目标格式

9.结构化报告与日志持久化入库

10.结果返回前端展示

## 2.4 交互与界面设计

界面采用“扁平化UI+可自定义背景”的现代设计风格，支持上传自定义背景图与自定义系统标题。仪表盘以统计卡片、等级环形图、近6个月趋势柱状图与报告数量TOP单位条形图呈现安全态势；各页面支持关键字搜索、分页与弹窗式快速编辑，AI对话与生成具备加载态、流式光标与Markdown/代码块渲染，交互流畅、学习成本低。

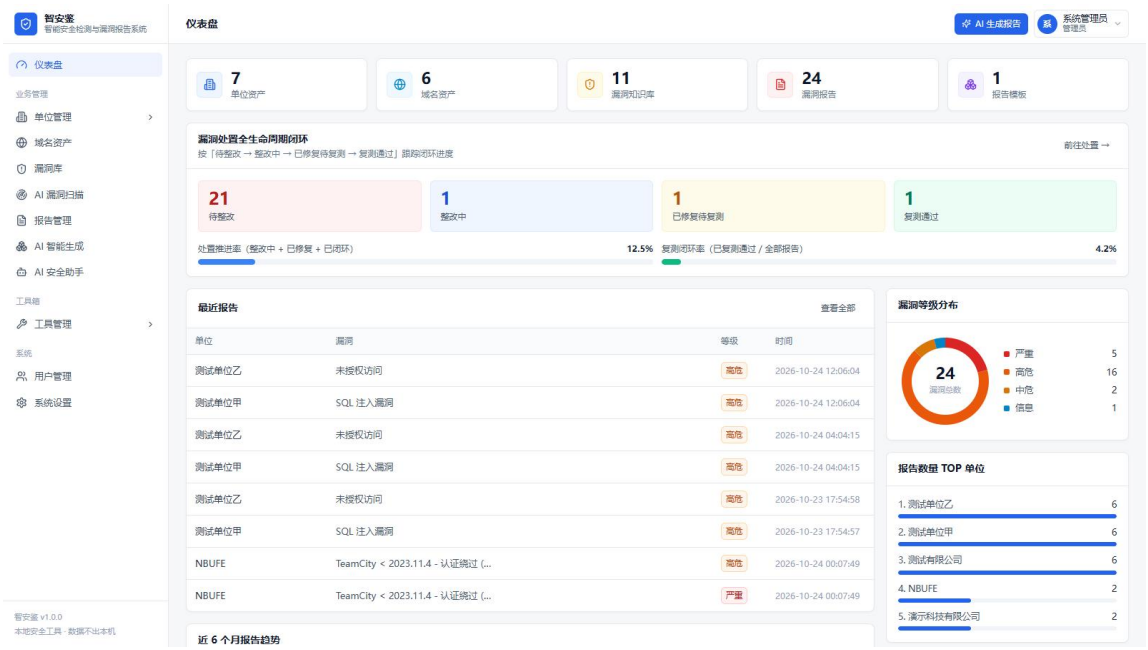



图2-13 系统仪表盘

（资产统计、漏洞处置全生命周期闭环看板、等级分布、近6个月趋势与TOP单位）

# 第三章 作品测试与分析

## 3.1 测试方案

测试采用“端到端自动化接口测试+浏览器真实操作验证+文档回读校验”相结合的方式。自动化测试脚本通过HTTP携带会话Cookie与CSRFToken调用真实运行的服务，覆盖页面渲染、全部业务接口与第二轮新增能力；浏览器侧使用自动化操作实际点击、上传文件、发送对话并截图留证；导出的Word/PDF采用文件头与字节大小、字体回读等方式校验，确保不是“假功能”。

## 3.2 测试环境

操作系统：Windows 10/11、Linux；

运行环境：Docker、Python 3（Flask/FastAPI/Celery）、Node.js（React/TypeScript/Vite）、MySQL 8、PostgreSQL 16、Redis 7、reportlab、python-docx/docxtpl；

浏览器：Chrome/Edge内核；

硬件：普通办公PC（4核CPU/8GB内存）即可流畅运行；

主应用默认监听8080端口以提供Web服务。

## 3.3 功能测试结果

交付前进行了全量测试:15个页面与15类只读接口全部正常响应；主要测试结果如下表：

| 测试模块 | 测试内容 | 预期结果 | 结果 |
| --- | --- | --- | --- |
| 单位/标签 | 批量/Excel/ICP导入、标签关联 | 正确入库去重、关联正确 | 通过 |
| 域名资产 | ICPJSON三格式<br>导入/查询/软删除 | 兼容并正确解析 | 通过 |
| 报告管理 | CRUD、批量导出、<br>检测/归属双图多图 | 内容与多张图片正确保存 | 通过 |
| 资产自动联动 | 填地址自动识别域名、<br>保存自动登记单位/域名 | 域名回填、资产幂等增记 | 通过 |

| | | | |
|---|---|---|---|
| 扫描器解析 | NucleiJSONL/通用JSON/纯文本 | 归一化条数与等级统计正确 | 通过 |
| CVSS评分 | 9.8/8.5/3.5/0.0等标准向量 | 与FIRST.org官方一致 | 通过 |
| 质量体检 | 多维度规则打分、单条/全量、重复检测 | 问题项与分数准确 | 通过 |
| Word导出 | 普通/公文/汇总/自定义模板 | 占位符与图片填充正确、版式一致 | 通过 |
| 模板逆向 | 上传成品docx预猜映射并生成模板 | 字段映射正确、再导出同版式 | 通过 |
| PDF导出 | 普通/公文/汇总，中文与图片 | 文件头%PDF、中文无乱码 | 通过 |
| RAG检索 | 本地漏洞库相似度召回 | 命中相关知识条目 | 通过 |
| AI生成 | 分析/润色/摘要/分类（模拟+真实Key） | 结构化JSON稳定输出 | 通过 |
| AICopilot | SSE流式多轮、思考模型reasoning分流 | 逐字流式、只呈现最终答案 | 通过 |
| 修复代码 | 根因/步骤/代码/验证/加固 | 结构化返回 | 通过 |
| 工具箱 | 密码/去重/提取/对比/分类/CVSS | 结果正确 | 通过 |
| 系统设置 | 背景/主题/AI配置/打开数据目录 | 即时生效、目录正常打开 | 通过 |
| AI漏洞扫描 | 内置引擎发起扫描、多目标并发、进度跟踪、结果自动回收、CVE 靶场检测 | 扫描任务正常执行、结果自动归一化入库 | 通过 |
| 用户认证 | 账号密码登录、管理员后台维护账号 | 登录校验通过、账号CRUD正常 | 通过 |
| 处置闭环 | 待整改→整改中→待复测→复测通过全链流转、非法跳变拦截 | 四态统计/轨迹/筛选/导出兼容均正确 | 通过 |
| 干净环境 | 全新解压库初始化+冒烟全流程 | 初始化即运行、 | 通过 |

表1 系统功能测试结果表

## 3.4 典型测试用例说明

（1）CVSS准确性：对向量CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H计算得9.8（Critical）；对含Scope改变的AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:L/A:N得8.5（High），验证了PR权重随Scope切换（0.62→0.68）的正确实现；全零影响向量正确判为0.0（None），非法向量被明确拒绝。

（2）扫描器解析：上传含4条记录的NucleiJSONL，系统准确识别来源为Nuclei并统计出高危2、中危1、低危1，数据自动填入待分析区。

（3）质量体检：对内容完整的演示报告给出81分（良好）并仅列出3条低级提示；对字段缺失的初始报告给出54分（待完善）并逐条列出6项可执行改进建议（如补全危害说明、分步整改与证据截图）。分数与问题数量随字段完整度明显变化，体现了体检引擎对交付质量的区分与闭环促进作用。

（4）PDF导出：普通/公文/汇总三类PDF均以%PDF-文件头正确生成，字节完整、中文（宋体/黑体/仿宋）无乱码、证据图片正常嵌入。

（5）资产联动与模板逆向：新建报告仅填写地址http://auto-liandongztest.cn:8848/nacos/保存后，域名被自动识别回填，单位与域名资产自动登记且归属正确，重复保存不产生重复记录；上传一份既有送检docx后，系统预猜并确认“段落→字段”映射，成功生成专属模板，再次导出时版式与原件一致。

（6）干净环境复跑：清空全部业务数据与APIKey后重新初始化，系统自动建立表结构、登记内置模板并导入虚构演示数据，无需任何手工配置即可运行全部页面、模拟AI与模板导出，验证了评委解压源码包后“开箱即跑”。

（7）漏洞处置闭环：在干净演示库中，对一份“待整改”报告依次执行开始整改、提交整改完成、复测通过，系统正确流转为“复测通过（闭环）”并追加3条带时间戳的整改轨迹；当尝试从“待整改”直接跳到“复测通过”时被后端拦截并提示按流程操作；复测不通过可回退到“整改中”。仪表盘四态计数（各1条）、处置推进率75%、复测闭环率25%实时刷新，按处置状态筛选与Word/PDF导出均正常。

（8）AI漏洞扫描：在AI漏洞扫描页输入测试目标地址并发起扫描，系统成功创建扫描任务并实时显示进度，扫描完成后自动回收结果并归一化解析，高危/中危/低危统计正确，结果自动填入待分析区可直接进入AI生成流程，全程无需手动导出导入。

（9）用户认证与管理：使用管理员账号登录成功进入系统，普通账号登录后权限受限；在管理员后台新增、编辑、删除账号均正常，未登录状态访问业务页面被正确拦截并跳转登录页。

## 3.5 结果分析

测试结果表明，系统功能完整、运行稳定：服务启动时间小于40秒，单条Word/PDF报告导出耗时小于5秒，扫描解析与RAG召回为毫秒级，AI流式对话速度取决于所选大模型接口。内置扫描引擎在普通办公PC环境下可稳定执行日常漏洞探测任务，CPU与内存资源占用较低，支持扫描任务与报告生成、AI对话等功能并行运行，互不影响。系统在无真实API Key时通过模拟模式仍可完整演示与联调全部AI相关流程，具备良好的可验证性与鲁棒性。

# 第四章 创新性和特色说明

（1）大模型+本地RAG双驱动：创新提出基于bigram的轻量级本地检索方案，无需向量数据库与向量模型，在零外部依赖条件下实现漏洞知识库相似度召回，将单位既有整改口径注入生成过程，显著降低大模型“幻觉”，使AI产出更贴合实际、可直接落地，兼顾了AI能力与输出可控性。

（2）“规则兜底+AI增强”的质量体检：将可解释的9维规则引擎与AI专家点评相结合，构建漏洞报告交付前的自动化质检体系，规则守底线、AI提上限，首次将“交付前自动质检”引入漏洞报告生产链路，改变行业长期依赖人工抽检的质量管控模式。

（3）标准化CVSSv3.1量化：严格遵循FIRST.org官方规范的评分引擎内置化，把主观的“高/中/低”经验判断转为可复核、可追溯的分值与向量串，统一团队等级判定口径，提升报告专业性与权威性。

（4）扫描—生成一体化闭环：内置多 Agent 调度的漏洞扫描引擎，将“发起扫描—自动回收结果—AI解析研判—报告生成导出”整合为一条流水线，打破传统“扫描工具出结果→人工导入→生成报告”的多工具割裂模式。实现从漏洞探测到报告交付的无缝衔接。

（5）漏洞全生命周期治理：内置四态状态机与整改轨迹留痕机制，配合流转合法性校验与仪表盘闭环率统计，把漏洞治理从单纯的“产出报告、通报问题”延伸到“整改跟踪、复测验证”的完整闭环，解决行业普遍存在的“只通报、不闭环”问题。

（6）成品报告逆向生成模板：Word/PDF双格式引擎+中文占位符自定义模板+成品报告逆向生成三位一体，既支持快速上手的内置模板，也能通过上传既有成品报告一键生成同版式模板，完美适配政企单位多样化的公文格式与送检要求。

（7）全流程AI Copilot与修复代码：从专家问答、流式对话到一键生成多语言修复代码，形成“发现—理解—修复”的智能辅助闭环，不仅输出报告，更提供落地整改的技术支撑。

（8）受控域安全部署：应用、数据库、缓存与扫描引擎均部署于受控部署域，密钥本地保存、数据不出部署域，配合CSRF防护、XSS防护、上传下载白名单等自身安全设计，在提供智能化能力的同时，满足政企单位对数据安全与合规的严苛要求，

且支持容器化快速交付、开箱即用。

（9）多用户认证与协作基础：引入账号密码登录与管理员后台，从单机单用户工具演进为支持多用户协作的平台，为团队协作、报告流转审批与权限隔离奠定架构基础。

**应用前景：**系统可用于渗透测试团队报告编制、高校网络安全实训、政企安全通报、等保测评与攻防演练等场景；后续可在已具备的处置闭环基础上扩展多用户协同与审批、漏洞知识图谱、对接扫描器定时任务的自动化复测，以及行业送检模板市场。

# 第五章 竞品分析

| 对比维度 | 扫描器自带报告 | 脚本化方案 | 商业安全平台 | 智安鉴 |
|---|---|---|---|---|
| 扫描多源解析 | 仅自身格式 | 需自行开发 | 部分 | Nuclei/Burp/JSON/文本 |
| CVSS量化 | 部分 | 无 | 部分 | v3.1精确内置 |
| 报告质量体检 | 无 | 无 | 弱 | 规则+AI双引擎 |
| RAG知识增强 | 无 | 无 | 部分云端 | 本地知识库、零依赖 |
| AI专家/修复代码 | 无 | 无 | 部分 | 流式Copilot+代码 |
| Word/PDF与模板 | 格式固定 | 需编程 | 受限 | 双格式、完全自定义 |
| 内置扫描引擎 | 无 | 无 | 部分 | 支持，扫描—生成一体化 |
| 多用户/权限 | 无 | 无 | 部分 | 账号登录+管理员后台 |
| 漏洞处置闭环 | 无 | 无 | 弱 | 四态状态机+轨迹+闭环率 |
| 数据本地化 | 是 | 是 | 多为云端 | 全本地、密钥本地 |
| 部署与上手 | 成本较高 | 高 | 高 | 低、开箱即用 |

表2 智安鉴与同类方案对比表

综合对比，智安鉴是目前少有的同时覆盖“漏洞探测—智能研判—报告生成—闭环治理”全流程的轻量化本地方案，在多源归一、CVSS量化、质量体检、本地RAG、双格式自定义模板与全流程AI辅助等方面形成了差异化的组合优势，且保持轻量本地部署与低上手门槛。

# 第六章 总结

本项目围绕网络安全漏洞检测与报告交付的四大行业痛点，设计并实现了智安鉴智能安全检测与漏洞报告系统，覆盖资产管理、内置漏洞扫描、多源结果解析、RAG智能研判、CVSS量化评分、报告全生命周期管理、规则+AI双重质量体检、成品报告模板逆向、Word/PDF多模板导出与安全专家Copilot的完整能力闭环。

系统从最初的漏洞报告生成工具，演进为集漏洞扫描、智能研判、报告生成、闭环治理于一体的本地化安全平台，能力边界从报告后处理延伸至前端探测，为网络安全测试、合规测评与漏洞治理提供全流程支撑。项目以覆盖32个程序模块、全部页面与接口、各类模板导出、资产联动及AI双通道的端到端回归，连同干净环境复跑与浏览器真实验证，证明了系统的真实性、稳定性与实用性。

下一步将重点完善多用户权限与报告流转审批机制，将本地RAG升级为可管理的漏洞知识图谱并支持反馈学习，扩展更多扫描器格式与批量自动复测能力，沉淀更多行业送检模板，持续提升系统的智能化水平与场景适配能力。